PROJECT

"Windows Credential Attack and Privilege Escalation"

Group 3

Names: Haikal Raihan Hafidz

Muhammad Salman Mu'aqil

Class: 4CS1

CONTINUING EDUCATION CENTER FOR COMPUTING AND INFORMATION TECHNOLOGY

FACULTY OF ENGINEERING, UNIVERSITY OF INDONESIA

2026

Windows Credential Attack and Privilege Escalation Project

Developed by

Haikal Raihan Hafizd
Muhammad Salman Mu'aqil

Windows Credential Attack and Privilege Escalation Penetration Testing

Project Title : Windows Credential Attack and Privilege Escalation

Batch Code : 4CS1

Start Date : March 2nd, 2026

End Date : March 2nd. 2026

Name of Faculty : Tri Agus Mulyadi

Names of Developer :

Haikal Raihan Hafidz

Muhammad Salman Mu'aqil

Date of Submission: March 2nd, 2026

ACKNOWLEDGEMENT

Authors would like to praise to Allah SWT, Most Merciful bless and so authors can finish this Project with the Title is “Windows Credential Attack and Privilege Escalation”. Author would like to thanks to Mr.Tri Agus Mulyadi, ST as Lecturer who has given useful suggestion which are help author in writing this paper.

The writer realized that this paper far from perfection, then the writer will be very unfettered the chest and was encouraged, if colleagues and the guide's agreeing lecturer gave the suggestion & criticism for this paper perfection.

I hope this paper can help readers in understanding how penetration testing works in windows using kali linux

.

Depok, February 25th 2026

Authors

SYSTEM ANALYSIS

This project simulates a small company network to show how weak security practices can lead to a full system compromise. The company uses Windows Server as a Domain Controller to manage user accounts and authentication through Active Directory. Employee computers run Windows 10 pro and are connected to the company domain so users can log in with their domain accounts. Sometimes, the IT administrator logs into employee computers to fix problems or perform maintenance, which is common in real companies.

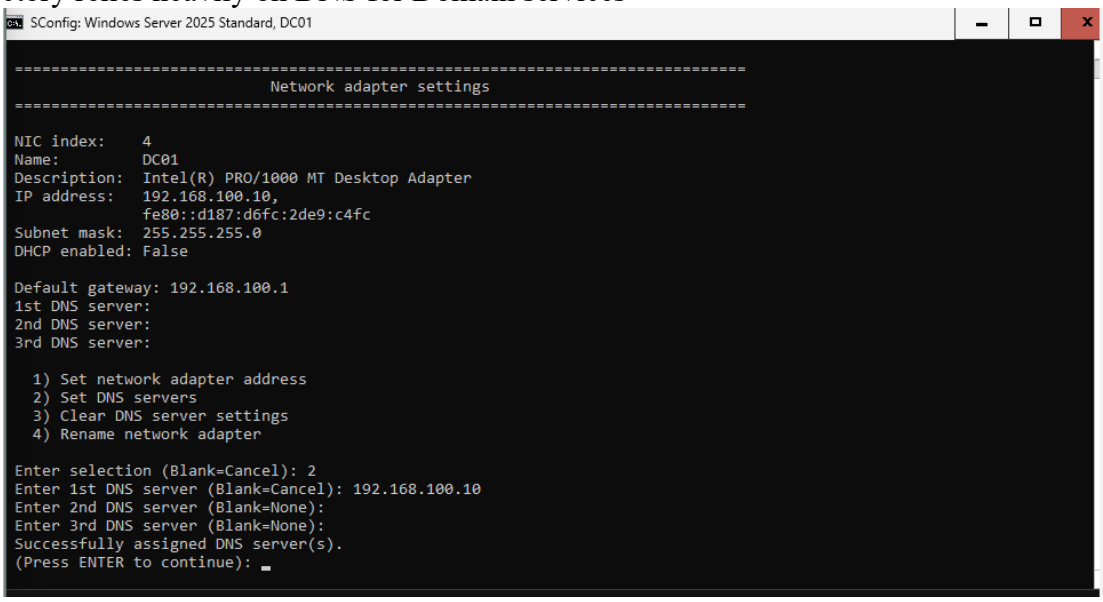
In this scenario, it is assumed that an attacker gains administrator access to one employee computer. The attacker machine runs Kali Linux and is connected to the internal network. Because the Domain Administrator previously logged into the compromised computer, login credentials are still stored on the system. The attacker extracts these credentials and uses them to access the Domain Controller. As a result, the attacker gains full control over the company's domain network.

This scenario shows that a company can be compromised not because of software bugs, but because of weak password management and unsafe administrative practices. It highlights the importance of protecting administrator accounts, using strong passwords, and securing all workstations in a domain environment.

Window Core (Server) Configuration

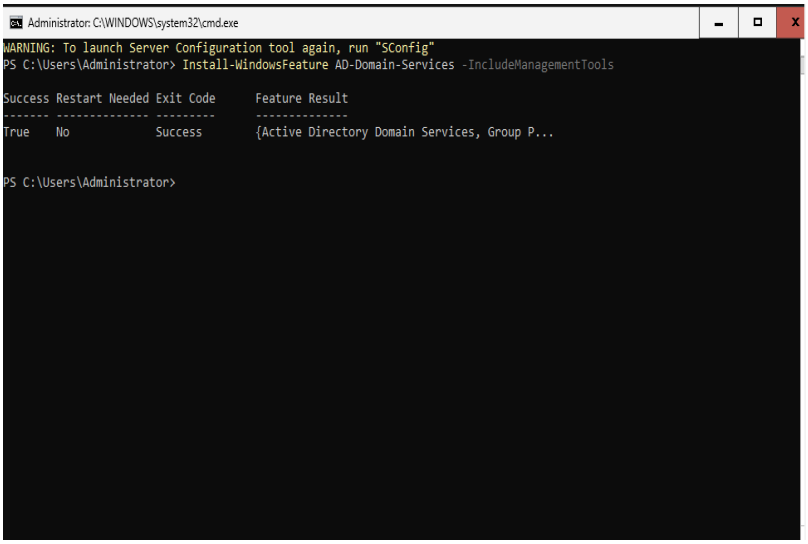
1. Configuring the Network

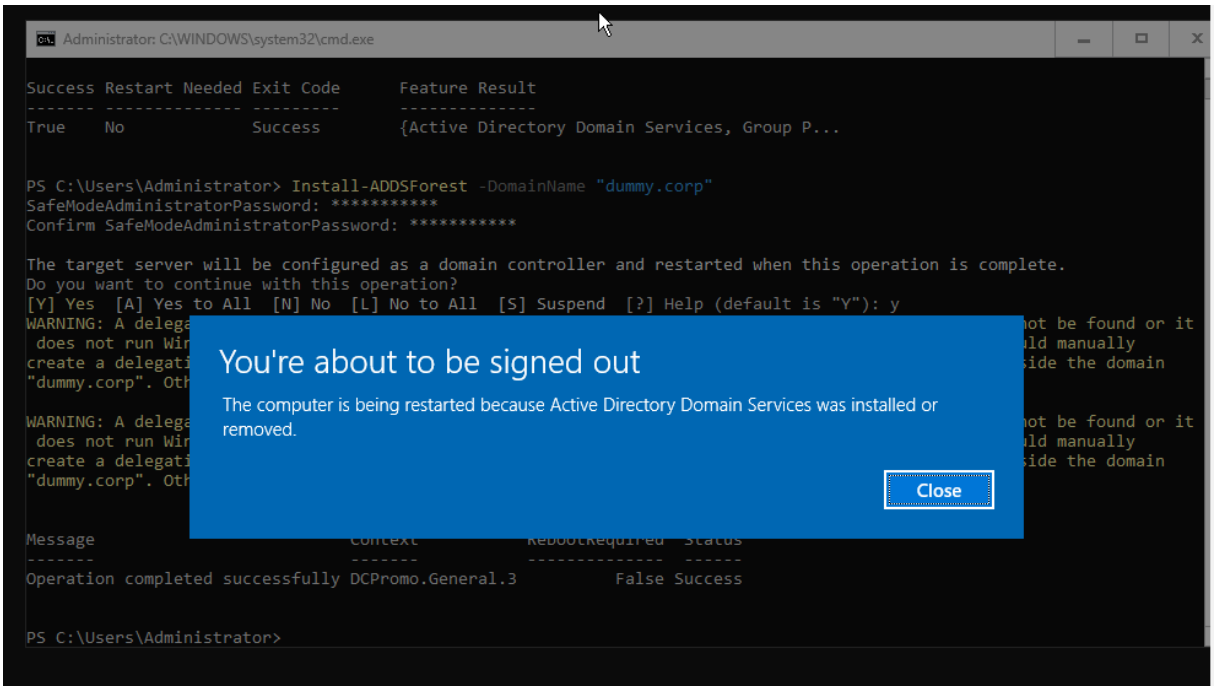
The Windows Server machine was configured as the Domain Controller of the simulated company network. First, a static IP address (192.168.100.10) is assigned to ensure consistent network communication. The DNS server was also set to its own IP address because Active Directory relies heavily on DNS for Domain services



2. Installing AD DS role

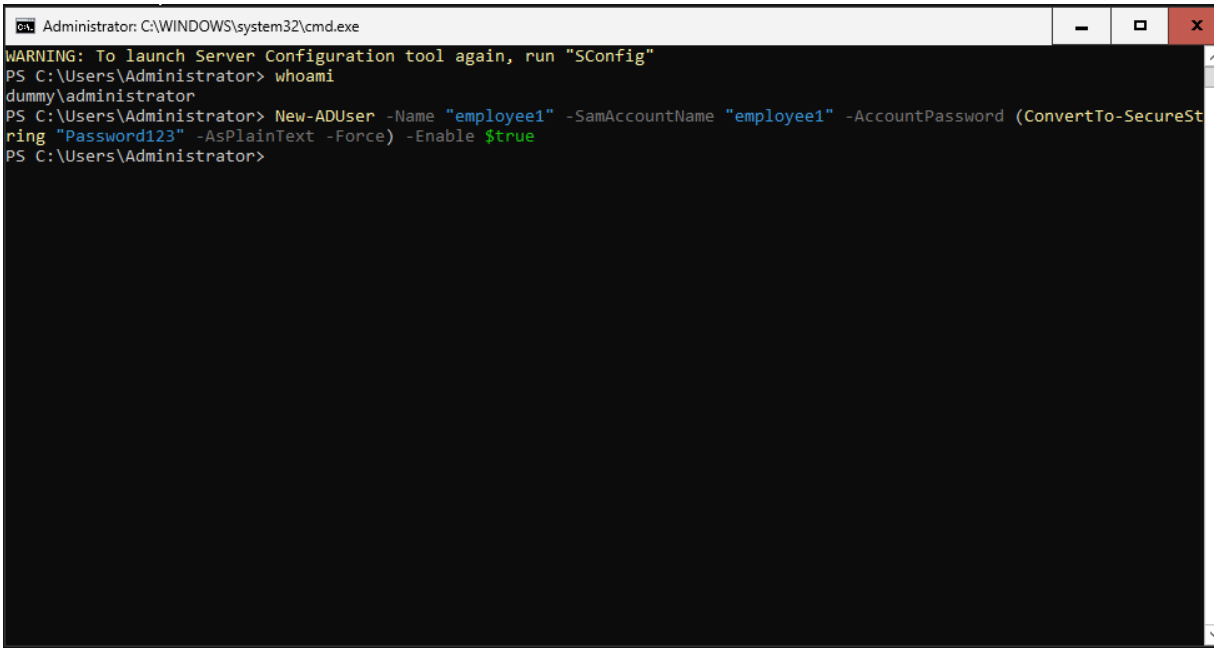
Next, the Active Directory Domain Service (ADDS) role was installed using the PowerShell with the `Install-WindowsFeature AD-Domain-Services` command. After installation, the server was promoted to a Domain Controller using `Install-ADDSForest`, and a new domain (dummy.corp) was created. Once the configuration process is finished, the server was restarted to apply the changes.





3. Creating domain users

After the reboot, domain user accounts were created using the New-ADUser PowerShell command. For example, a standard employee account named *employee1* was created with the password *Password123*. This user emulates a normal company employee. The Domain Administrator account was also used for administrative activities, including logging into the employee workstation for maintenance purpose.



Window 10 Configuration

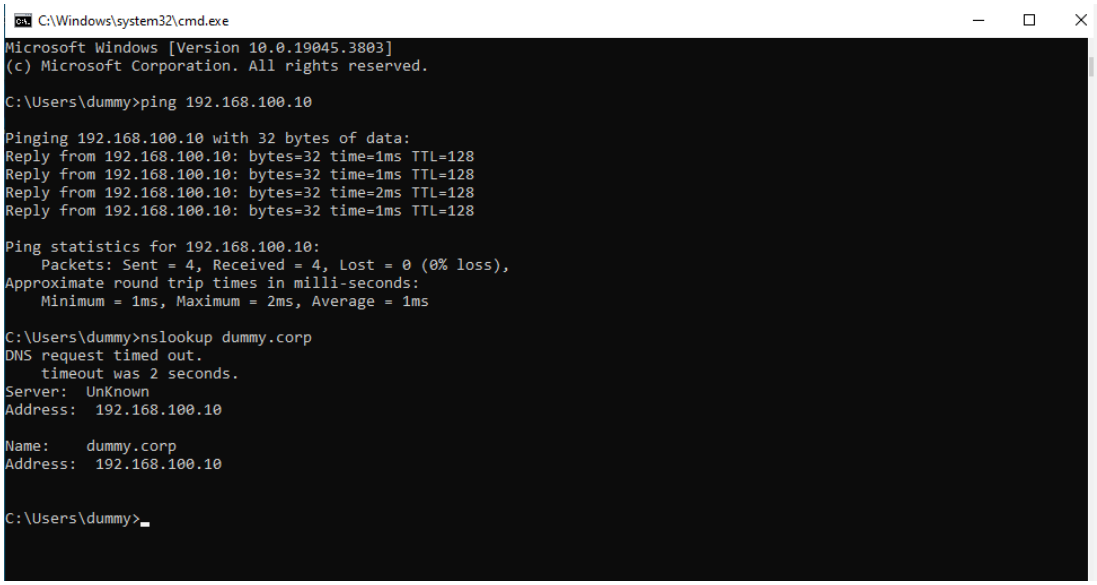
1. Configuring the Network

The Windows 10 Pro machine was configured as a domain-joined employee workstation. A static IP address (192.168.100.20) was assigned, and the DNS server was set to the Domain Controller's IP address (192.168.100.10). This ensures the workstation can locate the domain services

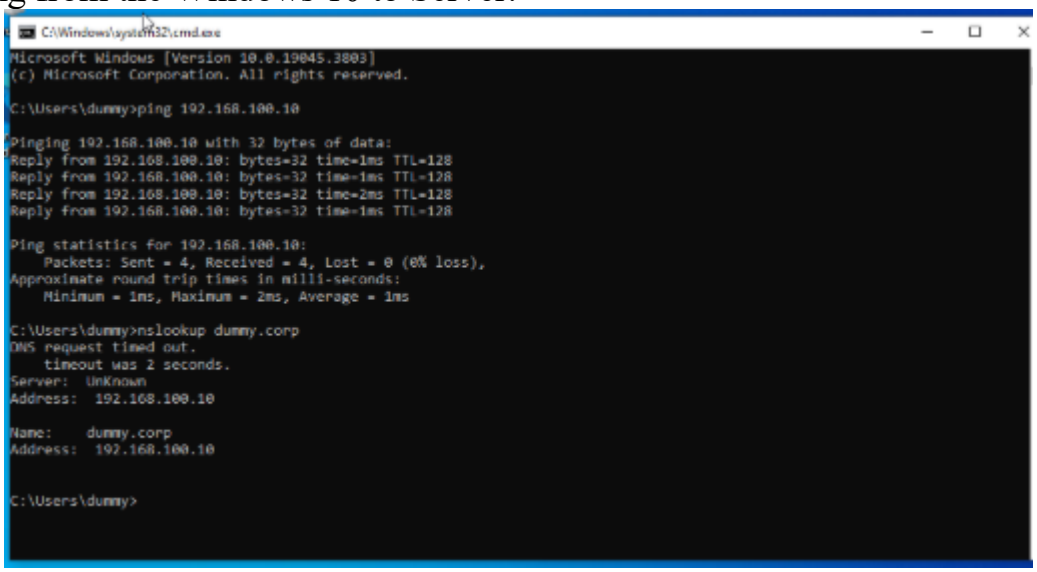
2. Try ping from both Server and Windows 10

Network connectivity was verified by using `ping` command between the Windows Server and Windows 10 machine. Successful replies confirmed proper communication within the internal network.

Pinging from Server to Windows 10:

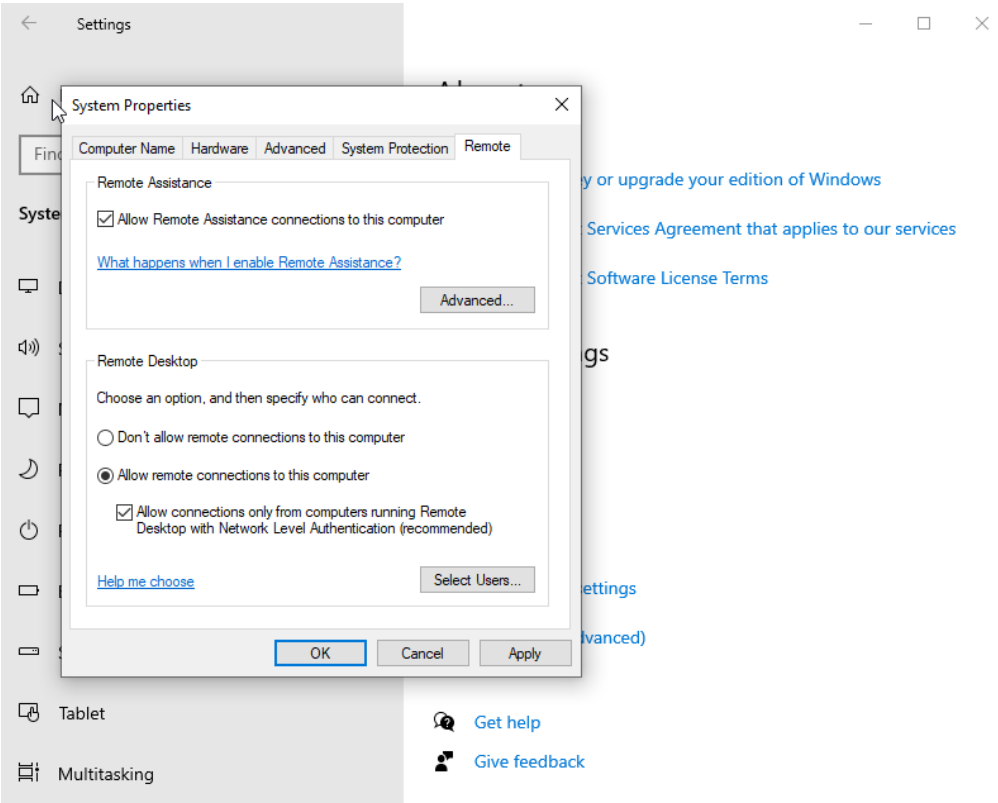


Pinging from the Windows 10 to Server:



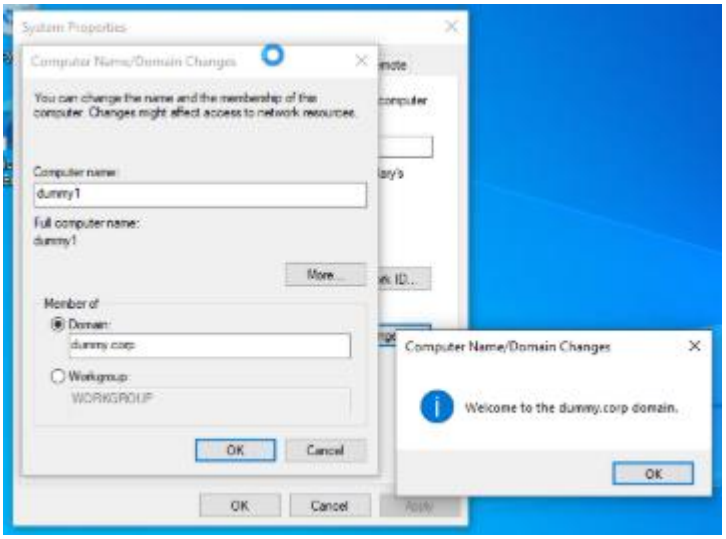
3. Enabling the RDP

Remote Desktop Protocol (RDP) was then enabled on the Windows 10 machine to simulate a realistic remote administration environment.

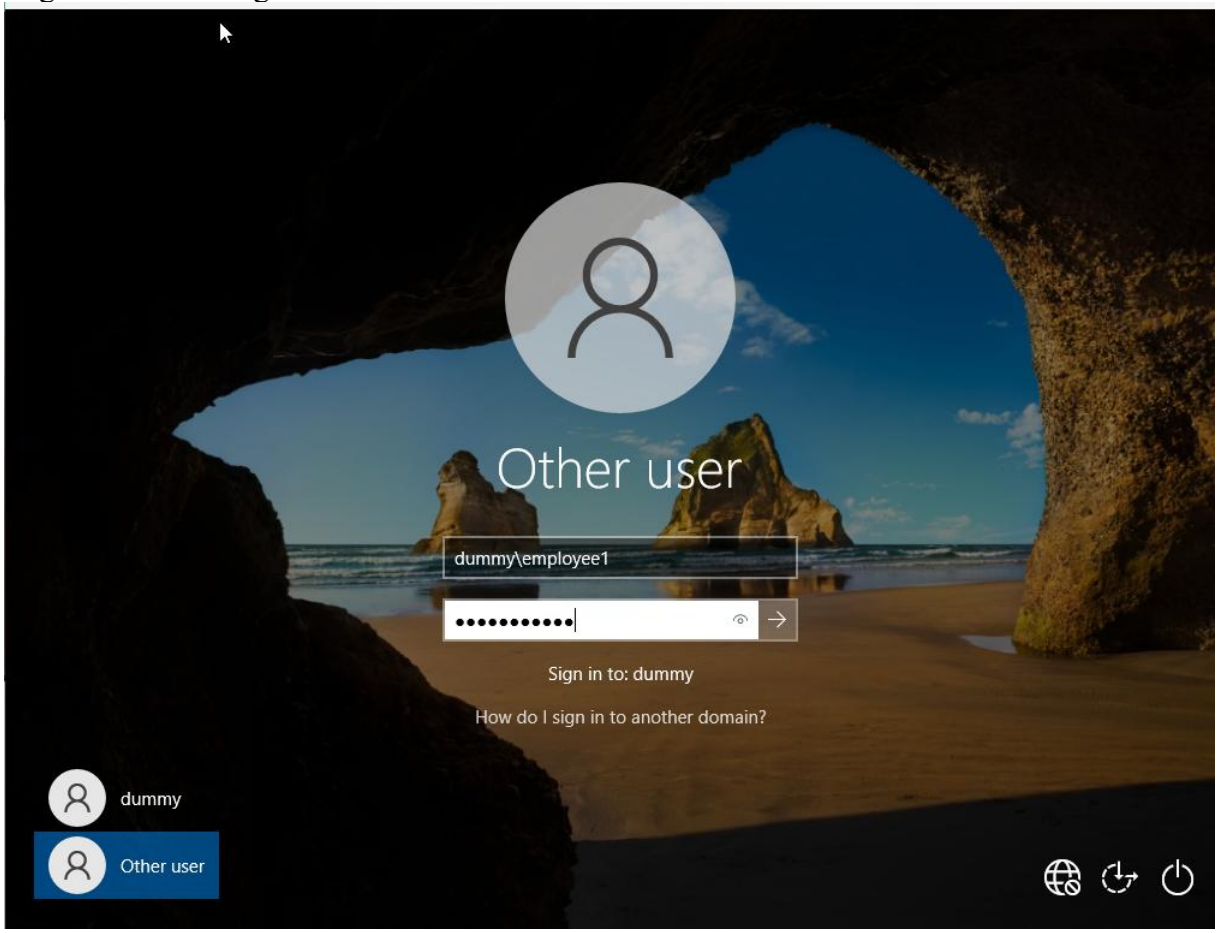


4. Joining the Domain from windows 10

After that, the workstation was joined to the dummy.corp domain through the system settings. The employee1 account was used to login to the system as a domain user. At some point, the Domain Administrator account also logged into this workstation, which later became important in the attack simulation.



Log in domain using user account



Kali Linux Configuration

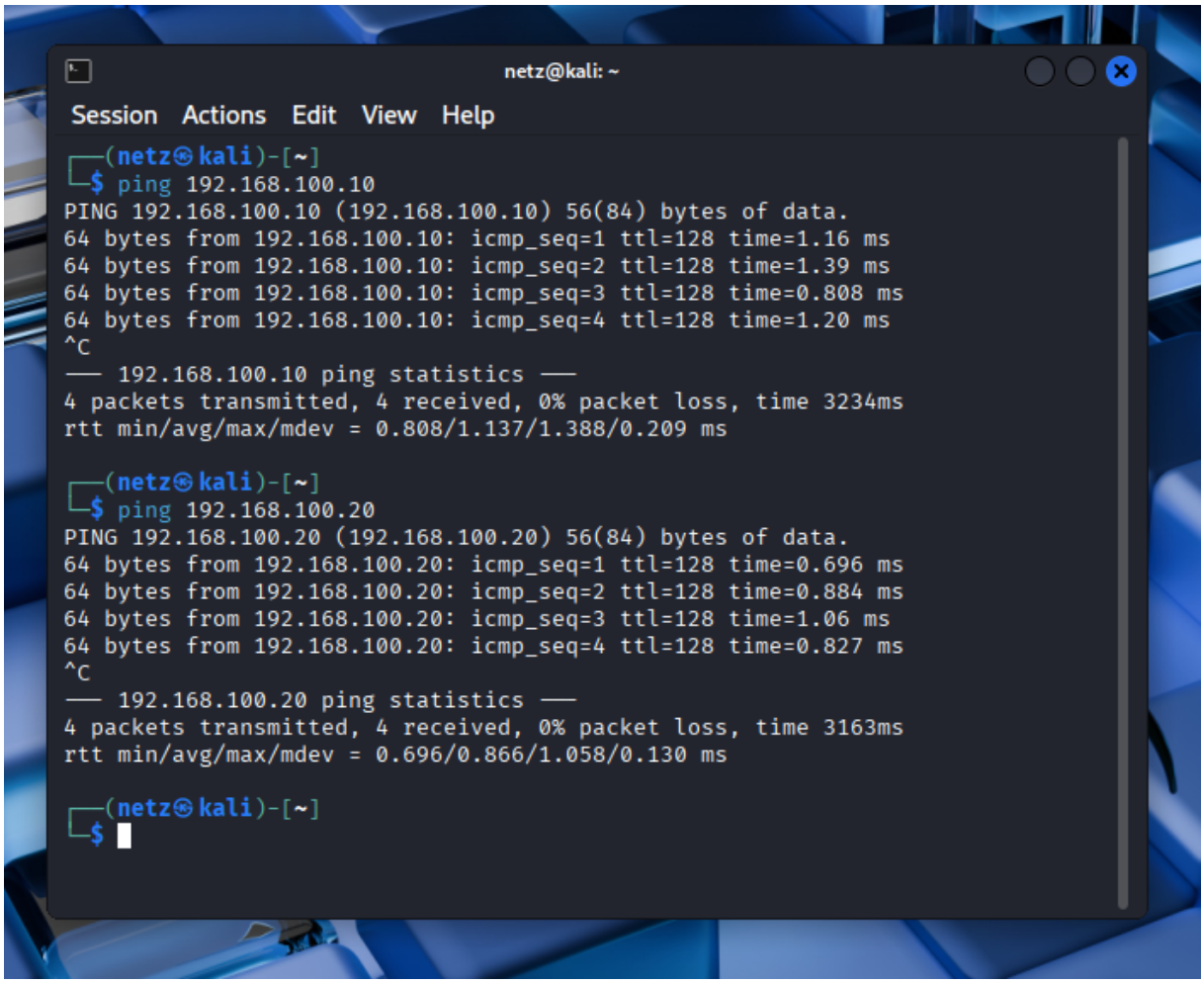
1. Setting the IP address into Static IP address

The Kali Linux machine was configured as the attacker system inside the same internal network. A static IP address was assigned within the 192.168.100.0/24 network range to allow communication with both the Domain Controller and the Windows 10 workstation.

```
┌──(netz㉿kali)-[~]
└─$ sudo nmcli connection add type ethernet ifname eth1 con-name hostonly-eth
1 ipv4.method manual ipv4.addresses 192.168.100.30/24
Connection 'hostonly-eth1' (93641b25-ab05-454a-9d8f-2ec5f28c021a) successfull
y added.

┌──(netz㉿kali)-[~]
└─$ sudo nmcli connection up hostonly-eth1
Connection successfully activated (D-Bus active path: /org/freedesktop/Networ
kManager/ActiveConnection/6)
```

2. Try pinging both the Windows Server and Windows 10

Connectivity was tested using the ping command to ensure the attacker machine could reach both 192.168.100.10 (Domain Controller) and 12.168.100.20 (Workstation). Kali Linux was equipped with penetration testing tools such as Nmap, kerbrute, CrackkMapExac, and THC Hydra, Which were used during the attack simulation.



Attack Simulation

1. Reconnaissance using nmap

The attack began with reconnaissance. The attacker used Nmap to scan the Domain Controller and identify the open ports and running services. The scan revealed important services such as Kerberos (port 88), LDAP (port 389), SMB (port 445), and DNS (port 53), confirming that the target machine was a Domain Controller

```
┌──(netz㉿kali)-[~]
└─$ nmap -sn 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 07:32 EST
Nmap scan report for 192.168.100.1
Host is up (0.00044s latency).
MAC Address: 0A:00:27:00:00:13 (Unknown)
Nmap scan report for 192.168.100.10
Host is up (0.00027s latency).
MAC Address: 08:00:27:E7:FE:36 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.100.20
Host is up (0.00089s latency).
MAC Address: 08:00:27:AF:71:CD (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Nmap scan report for 192.168.100.30
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.33 seconds

┌──(netz㉿kali)-[~]
└─$ nmap -p 88,389,445,53 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 07:33 EST
Stats: 0:00:03 elapsed; 252 hosts completed (3 up), 3 undergoing SYN Stealth
Scan
SYN Stealth Scan Timing: About 70.83% done; ETC: 07:33 (0:00:01 remaining)
Nmap scan report for 192.168.100.1
Host is up (0.00049s latency).

PORT    STATE    SERVICE
53/tcp  filtered domain
88/tcp  filtered kerberos-sec
389/tcp filtered ldap
445/tcp open     microsoft-ds
MAC Address: 0A:00:27:00:00:13 (Unknown)

Nmap scan report for 192.168.100.10
Host is up (0.00071s latency).

PORT    STATE SERVICE
53/tcp  open  domain
88/tcp  open  kerberos-sec
389/tcp open  ldap
445/tcp open  microsoft-ds
```

```
┌──(netz㉿kali)-[~]
└─$ nmap -p 88,389,445,53 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 07:33 EST
Stats: 0:00:03 elapsed; 252 hosts completed (3 up), 3 undergoing SYN Stealth
Scan
SYN Stealth Scan Timing: About 70.83% done; ETC: 07:33 (0:00:01 remaining)
Nmap scan report for 192.168.100.1
Host is up (0.00049s latency).

PORT    STATE    SERVICE
53/tcp  filtered domain
88/tcp  filtered kerberos-sec
389/tcp filtered ldap
445/tcp open     microsoft-ds
MAC Address: 0A:00:27:00:00:13 (Unknown)

Nmap scan report for 192.168.100.10
Host is up (0.00071s latency).

PORT    STATE SERVICE
53/tcp  open  domain
88/tcp  open  kerberos-sec
389/tcp open  ldap
445/tcp open  microsoft-ds
MAC Address: 08:00:27:E7:FE:36 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap scan report for 192.168.100.20
Host is up (0.00088s latency).

PORT    STATE    SERVICE
53/tcp  filtered domain
88/tcp  filtered kerberos-sec
389/tcp filtered ldap
445/tcp filtered microsoft-ds
MAC Address: 08:00:27:AF:71:CD (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Nmap scan report for 192.168.100.30
Host is up (0.0014s latency).

PORT    STATE  SERVICE
```

2. Scanning port 389

```
netz@kali: ~
Session  Actions  Edit  View  Help
┌──(netz㉿kali)-[~]
└─$ nmap -p 389 --script ldap-rootdse 192.168.100.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-26 07:36 EST
Nmap scan report for 192.168.100.10
Host is up (0.00049s latency).

PORT    STATE SERVICE
389/tcp open  ldap
| ldap-rootdse:
| LDAP Results
|   <ROOT>
|       domainFunctionality: 10
|       forestFunctionality: 10
|       domainControllerFunctionality: 10
|       rootDomainNamingContext: DC=dummy,DC=corp
|       ldapServiceName: dummy.corp:dc01$@DUMMY.CORP
|       isGlobalCatalogReady: TRUE
|       supportedSASLMechanisms: GSSAPI
|       supportedSASLMechanisms: GSS-SPNEGO
|       supportedSASLMechanisms: EXTERNAL
|       supportedSASLMechanisms: DIGEST-MD5
|       supportedLDAPVersion: 3
|       supportedLDAPVersion: 2
|       supportedLDAPPolicies: MaxPoolThreads
|       supportedLDAPPolicies: MaxPercentDirSyncRequests
|       supportedLDAPPolicies: MaxDatagramRecv
|       supportedLDAPPolicies: MaxReceiveBuffer
|       supportedLDAPPolicies: InitRecvTimeout
|       supportedLDAPPolicies: MaxConnections
|       supportedLDAPPolicies: MaxConnIdleTime
|       supportedLDAPPolicies: MaxPageSize
|       supportedLDAPPolicies: MaxBatchReturnMessages
|       supportedLDAPPolicies: MaxQueryDuration
|       supportedLDAPPolicies: MaxDirSyncDuration
|       supportedLDAPPolicies: MaxTempTableSize
|       supportedLDAPPolicies: MaxResultSetSize
|       supportedLDAPPolicies: MinResultSets
|       supportedLDAPPolicies: MaxResultSetsPerConn
|       supportedLDAPPolicies: MaxNotificationPerConn
|       supportedLDAPPolicies: MaxValRange
|       supportedLDAPPolicies: MaxValRangeTransitive
|       supportedLDAPPolicies: ThreadMemoryLimit
|       supportedLDAPPolicies: SystemMemoryLimitPercent

|       namingContexts: DC=ForestDnsZones,DC=dummy,DC=corp
|       isSynchronized: TRUE
|       highestCommittedUSN: 20522
|       dsServiceName: CN=NTDS Settings,CN=DC01,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=dummy,DC=corp
|       dnsHostName: DC01.dummy.corp
|       defaultNamingContext: DC=dummy,DC=corp
|       currentTime: 20260227024303.0Z
|_      configurationNamingContext: CN=Configuration,DC=dummy,DC=corp
MAC Address: 08:00:27:E7:FE:36 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: DC01; OS: Windows

Nmap done: 1 IP address (1 host up) scanned in 0.40 seconds
```

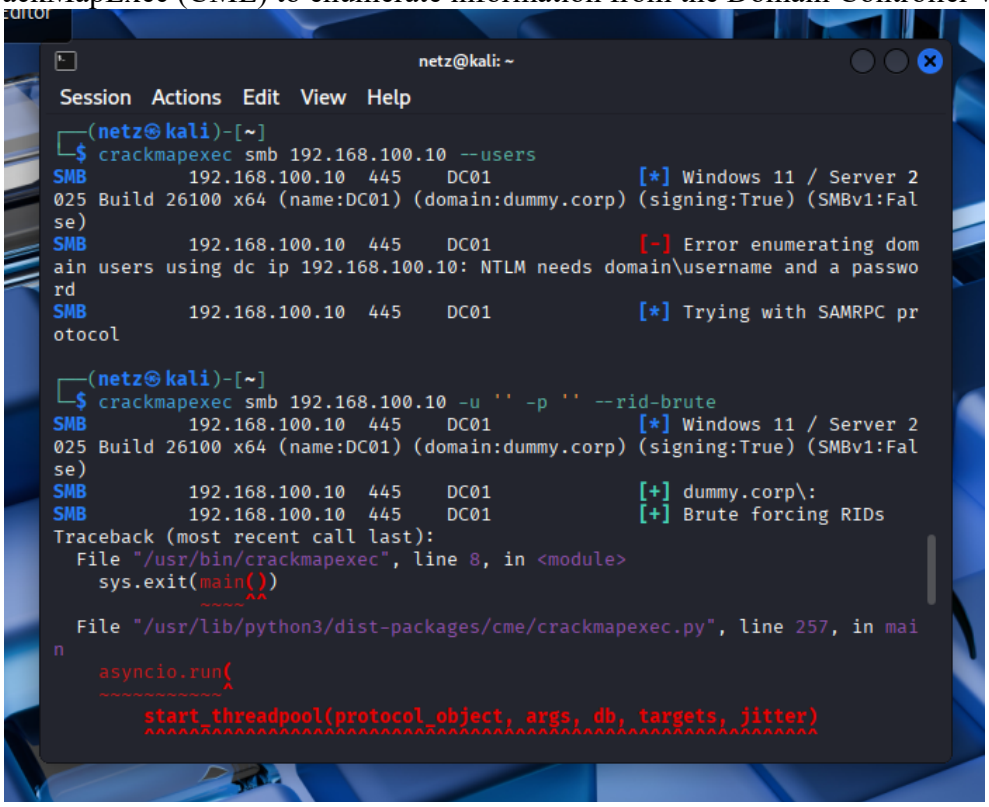
3. Prepare Kerbrute to obtain the Username from the domain

Next, Kerbrute was used to enumerate valid usernames in the domain. By sending authentication requests to the Kerberos service, the attacker was able to identify which username existed in the domain without needing passwords.

```
netz@kali: ~
Session  Actions  Edit  View  Help
2026/02/26 08:57:11 >  open Documents/wordlistsgue/userlists.txt: no such fil
e or directory

┌──(netz㉿kali)-[~/Documents]
└─$ cd

┌──(netz㉿kali)-[~]
└─$ ~/go/bin/kerbrute userenum --dc 192.168.100.10 -d dummy.corp Documents/wo
rdlistsgue/userlists.txt

Version: dev (n/a) - 02/26/26 - Ronnie Flathers @ropnop

2026/02/26 08:57:38 >  Using KDC(s):
2026/02/26 08:57:38 >   192.168.100.10:88

2026/02/26 08:57:38 >  [+] VALID USERNAME:       administrator@dummy.corp
2026/02/26 08:57:38 >  [+] VALID USERNAME:       employee1@dummy.corp
2026/02/26 08:57:38 >  Done! Tested 18 usernames (2 valid) in 0.027 seconds

┌──(netz㉿kali)-[~]
└─$
```

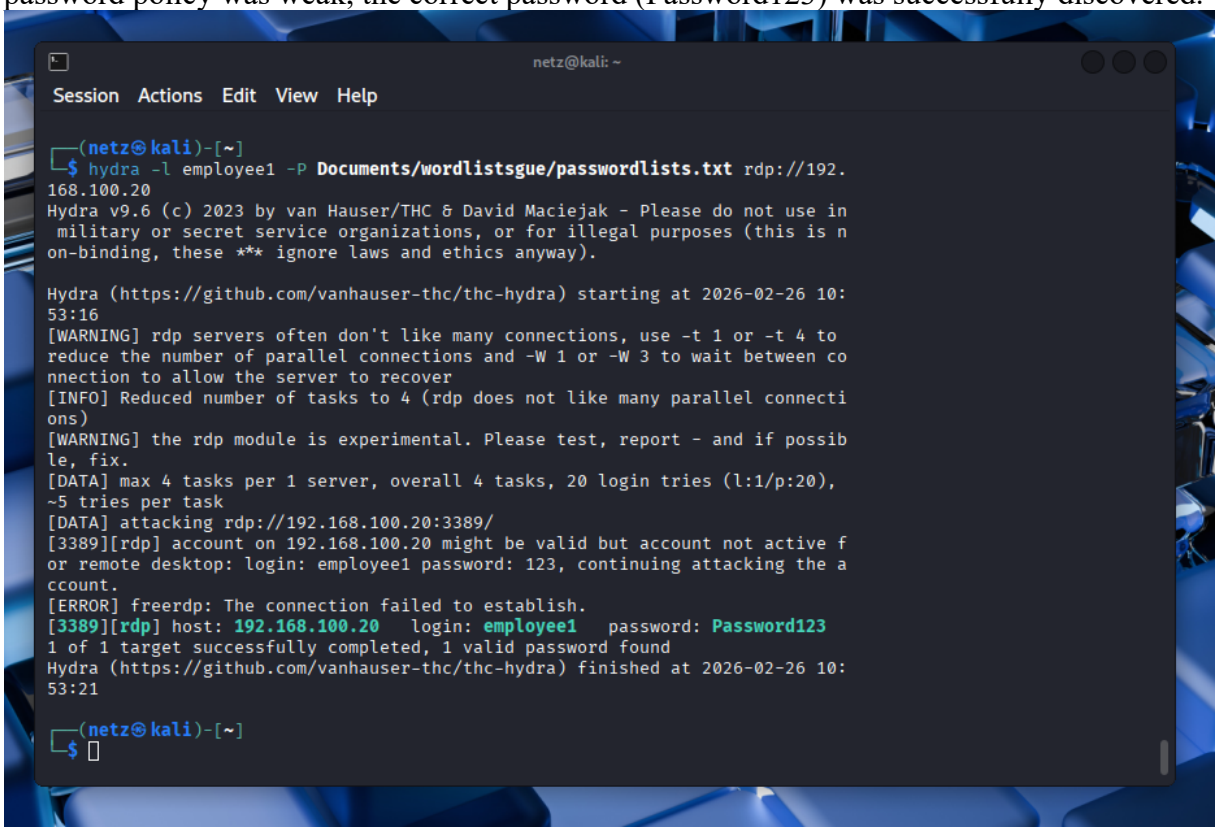
4. Use CrackMapExec (CME)

Using CrackMapExec (CME) to enumerate information from the Domain Controller via SMB



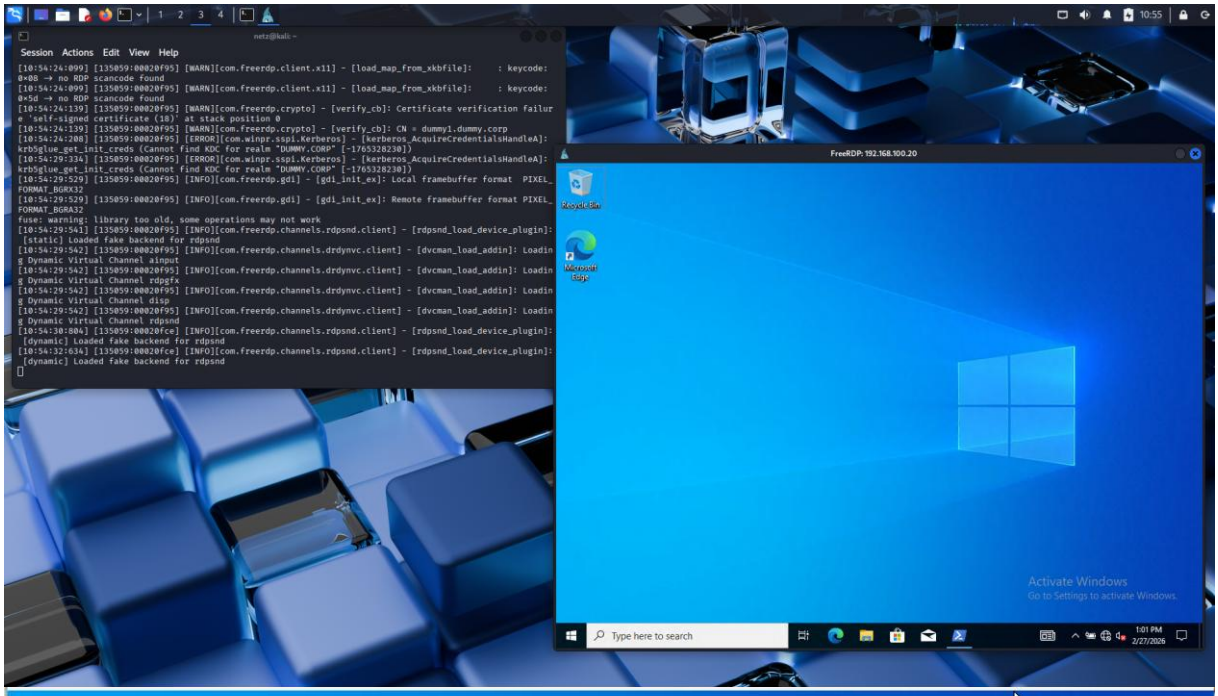
5. Use THC Hydra

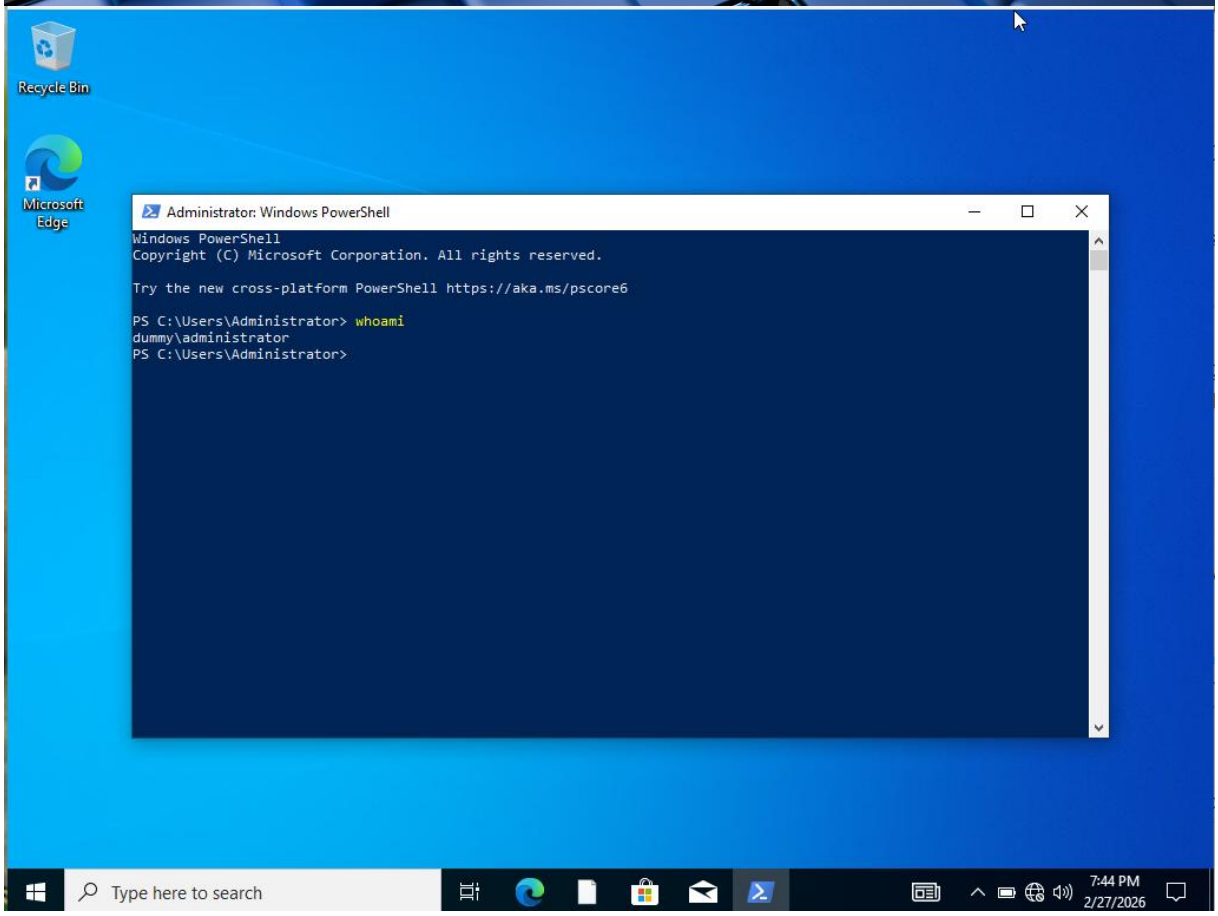
After obtaining a valid username (employee1), THC Hydra was used to perform a password brute-force attack against the RDP service of the Windows 10 workstation. Because the password policy was weak, the correct password (Password123) was successfully discovered.



6. Log in from RDP

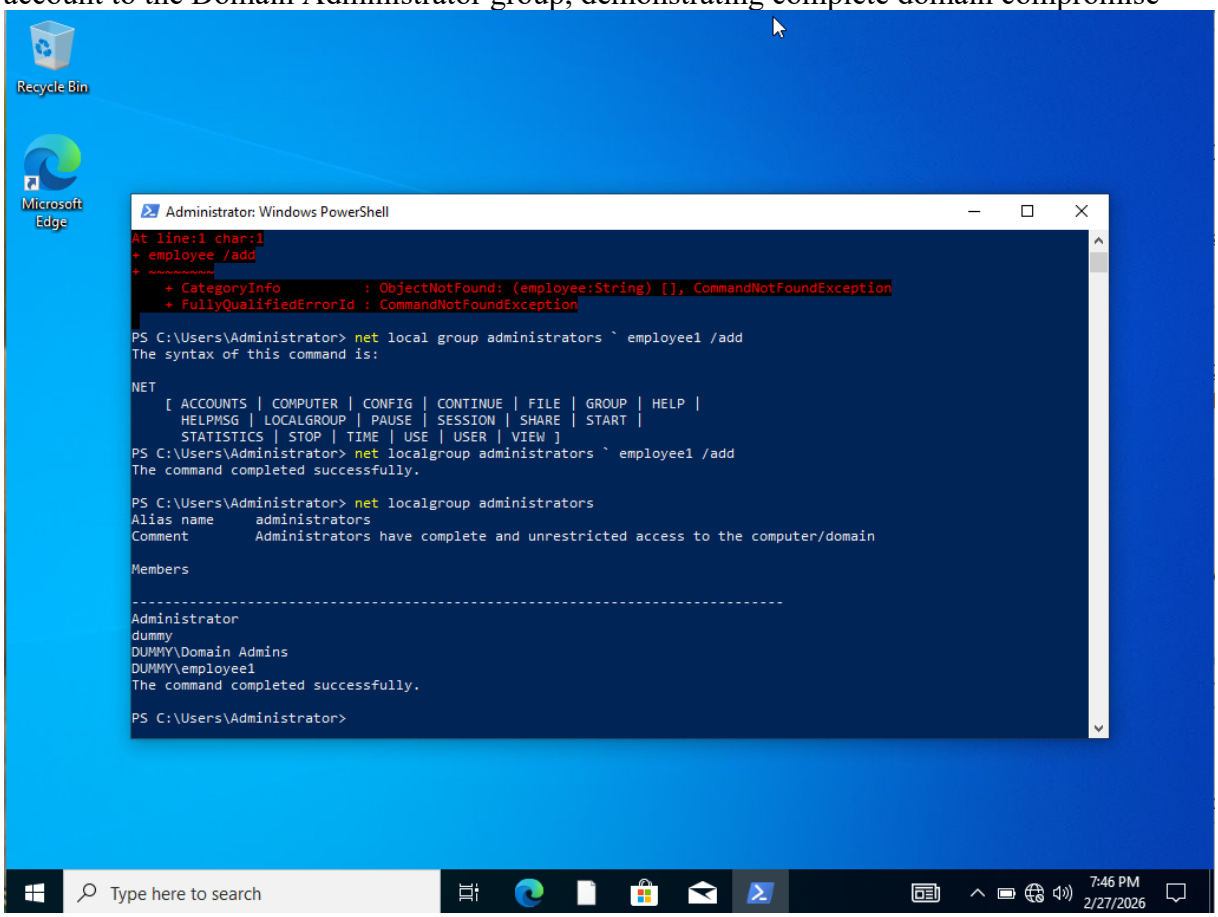
Using the valid credentials, the attacker logged into the Windows 10 workstation via RDP. Since the Domain Administrator had previously logged into the same machine, administrator credentials were cached in memory. These credentials could then be extracted and reused to access the Domain controller





7. Adding the employee user to administrator domain

Finally, the attacker used the compromised Domain Administrator account to log into the Domain Controller and gain full control over the domain. The attacker then added the employee account to the Domain Administrator group, demonstrating complete domain compromise



Conclusion and Suggestion

1. Conclusion

This project demonstrate how a small enterprise network can be fully compromised without exploiting any software vulnerabilities. Instead of using complex exploits, the attack relied on weak password practices, exposed services, and unsafe administrative behavior. By compromising a single domain-joined workstation, the attacker was able to enumerate valid usernames, perform password brute forcing, and eventually gain access to privileged accounts.

The simulation clearly shows how cached credentials and poor password hygiene can lead to privilege escalation and full domain takeover. When the Domain Administrator logged into a regular workstation, sensitive credentials could be reuse to compromise the Domain Controller. This highlights how one insecure endpoint ca put the entire organization at risk.

Overall, the project emphasizes that strong security practices and proper administrative controls are critical in protecting enterprise environment from internal network attacks.

2.Suggestion

To prevent similar attack from happening in real organizations, several security measures should be implemented

1.Strong Password

Organization must enforce strong password policies. Passwords should be complex, long, and regularly updated. Account lockout policies should also be enabled to prevent brute-force attacks. Multi-factor Authentication (MFA) should be implemented, especially for privileged accounts such as Domain Administrator.

2.Adminstrator Account Usage

Administrator accounts should not be used to log into regular employee workstations. Instead, administrator should use dedicated management system or privileged access workstations. This reduces the risk of credential caching on less secure devices.

3.Disable Unnecessary Services

Unnecessary services such as RDP should be restricted. Remote Desktop access should be limited through firewall rules, VPN access, or network segmentation. Only authorized users should be allowed to access critical services

4.Adding Security Systems

Monitoring and logging systems should be deployed to detect suspicious activity such as multiple failed login attempts, abnormal authentication requests, or unusual network scanning behavior. Security tools like intrusion detection systems and centralized log management can help identify attacks early.

By implementing these preventive measures, organizations can strengthen their security posture and reduce the likelihood of domain-wide attacks similar to the one demonstrated in this project

SOFTWARE SPECIFICATION

Hardware :

1.

Operating System :

- **Kali Linux**
- **Window 10 pro**
- **Window Server**

Software :

- **Virtual Box**
- **Ms. Word**
- **Canva**
- **Virtual Box**

Tools :

- **Nmap**
- **Mimikatz**
- **John the ripper**
- **Impacket**
- **RDP**
- **TCP Hydra**